

Cybernara Database Schema Gap Report

Production-readiness assessment of the current Supabase/PostgreSQL schema against the Master PRD, Engineering Requirements, and Final Architecture.

Document owner	Swapnil Khedkar
Classification	Cybernara confidential doc
Version	v1.0 - Final Gap Assessment
Date	2 July 2026
Deployment	Private cloud - mid-market and enterprise
Deliverable	Prioritized findings, requirement impact, target-state remediation, migration plan and acceptance gates

CYBERNARA CONFIDENTIAL - Do not distribute without written authorization.

1. Executive Verdict

The current schema is a credible implementation foundation, particularly in migration control, RLS enablement, outbox processing, connector operations, content ingestion diagnostics, and platform hardening. It is not yet sufficient as the production system of record for the complete Cybernara product. The primary issue is domain incompleteness and weakened referential integrity, not the choice of PostgreSQL or Supabase.

Dimension	Assessment	Decision
Migration and deployment	Strong foundation	Retain transactional migration runner, history and dry-run behavior.
Tenant isolation	Partially evidenced	Retain RLS; add policy semantics, bypass controls and negative isolation tests.
Framework content	Operational but incorrectly scoped	Separate global signed catalog from tenant custom overlays.
Assessment/evidence	Materially incomplete	Replace with normalized execution, evidence and snapshot graph.
AI	Useful skeleton	Extend to full retrieval, citation, safety, evaluation and approval provenance.
Privacy/GRC	Over-compressed	Normalize key relationships and complete workflow entities.
Reporting/audit	Partially strong	Persist immutable report artifacts and harden ordered audit chaining.
Overall	Not production-ready for Master PRD	Proceed through staged additive migration and verification gates.

Recommendation

Use the current migrations as the operational base, not as the final domain model. Implement the target schema specified in the companion Production Database Schema Specification through backward-compatible additive migrations, data backfills, dual reads/writes where necessary, verification, and controlled removal of compromised structures.

2. Prioritized Gap Register

ID	Severity	Area	Gap	Required remediation	Traceability
G-01	Critical	Assessment execution	No control_instances, answer revisions, applicability decisions, reviewer decisions, tests, scopes or snapshots.	Add normalized assessment execution aggregate and immutable snapshot graph.	ASM-01..07
G-02	Critical	Referential integrity	findings.assessment_item_id lacks FK; mappings use text IDs; privacy links use UUID arrays/JSON.	Replace with UUID FKs and associative tables; defer only where cycle handling requires it.	FRM-04, PRV-01..07
G-03	Critical	Risk acceptance	Reason exists only in audit/outbox payloads and task status.	Create risk_acceptances with approver, rationale, expiry, compensating controls and review history.	GRC-01, ASM-06
G-04	Critical	Report immutability	Downloads may re-render rather than serve a frozen immutable artifact.	Persist generated bytes, snapshot ID, template/runtime version, hash, signature and manifest.	RPT-01
G-05	High	Framework catalog ownership	Standard content is tenant-owned, causing duplication and inconsistent upgrades.	Separate global/deployment catalog from tenant custom overlays and subscriptions.	FRM-01..06
G-06	High	AI provenance	No explicit retrieved chunks, citations, safety checks, evaluation suites/cases/results or publication approval.	Add complete generation, retrieval, safety, evaluation and approval lineage.	AI-01..08
G-07	High	Evidence graph	Evidence objects are not fully linked to control instances, questions, tests, periods, requests or reviews.	Add evidence_links, evidence_versions, requests, reviews, samples and retention actions.	EVD-01..06
G-08	High	Privacy normalization	Processing, purposes, lawful bases, recipients, transfers and retention relationships are compressed into arrays/JSON.	Create typed entities and join tables with effective dating and deletion workflow.	PRV-01..07
G-09	High	Enterprise GRC depth	No complete risk, treatment, access-review item, vendor assessment, audit request/test or policy attestation model.	Add full enterprise GRC aggregates and relationship tables.	GRC-01..08
G-10	High	Tenant security assurance	RLS object count proves existence, not predicate correctness or bypass safety.	Add policy catalog, automated negative tests, service-role controls and object/search isolation verification.	SEC-01..04
G-11	Medium	Audit hash chain	Previous-hash model lacks documented per-tenant ordering and concurrency strategy.	Add monotonic sequence, chain partition, unique constraints, signing checkpoints and verifier results.	SEC-03
G-12	Medium	Retention and deletion	Schedules exist but no subject/object holds, deletion jobs, proof or cryptographic erasure workflow.	Add holds, retention assignments, deletion jobs/items and destruction attestations.	PRV-07, SEC-04
G-13	Medium	Custom platform	Definitions exist without fields, records, values, validation, permissions or workflow binding.	Add normalized metadata model and guarded extension indexes.	GRC-08
G-14	Medium	Physical design evidence	Schema audit checks named objects but not query plans, constraints, RLS behavior, partition health or recovery.	Expand assurance suite to behavioral and performance verification.	NFR/SRE

3. Requirement Coverage Comparison

Domain	Current coverage	Missing production capabilities	Target tables
Identity and tenancy	Tenants, users, roles, sessions, service accounts, delegations	Workspace memberships, group claims, permission catalog, MFA/auth events, tenant key/region history	identity.* and workspace.*
Frameworks	Source packages, packs, requirements, controls, mappings, rejects	Global catalog, releases, approval history, citations, mapping versions, conflicts, subscriptions and overlays	catalog.*
Assessment	Assessments and items	Scopes, snapshots, control instances, applicability, questions, answers, tests, decisions and sign-offs	assessment.*
Evidence	Evidence object	Versions, links, requests, reviews, samples, chain of custody, expiry and disposal	evidence.*
Risk/workflow	Findings and tasks	Risk register, treatment, acceptance, SLA, comments, approval and verification	risk.* / workflow.*
AI	Prompts, model, index, generation, question, review	Chunks, citations, safety, policy checks, evaluation suites/cases/results and publish events	ai.*
Privacy	Seven high-level records	Normalized processing graph, request tasks, incident notifications, transfers, holds and deletion proof	privacy.*
Enterprise GRC	Policies, access review, vendor, audit, trust artifact, custom definition	Versions/attestations, review items, assessments, requests/tests, access gates, custom records	grc.* / trust.*
Reporting	Export metadata	Frozen snapshots, stored artifacts, template/runtime versions, signatures, manifests and schedules	reporting.*
Platform	Strong operational tables	Behavioral policy assurance, audit ordering, retention execution and projection reconciliation	platform.* / audit.*

4. Strengths to Preserve

- Seven ordered transactional migrations with migration-history rows and dry-run support.
- RLS enabled across tenant tables and explicit tenant_id propagation.
- Transactional outbox with idempotency constraints.
- Content-source checksums and rejected-record diagnostics.
- Connector sync runs, external-object identity, webhook deliveries and control-test foundations.
- Authorization decision logs, rate-limit policy, key inventory, SIEM delivery, backup tests, release gates and upload scanning.

5. Remediation Sequence

Phase	Actions	Exit gate
1 - Guard rails	Add missing FKs where safe; introduce global catalog scope; add RLS behavioral tests; freeze incompatible new array/JSON writes.	No new orphaned or cross-tenant records.
2 - Core execution	Create scope/snapshot/control-instance/answer/evidence-link/test/reviewer/risk-acceptance tables.	End-to-end assessment is fully relational and reproducible.
3 - Privacy and GRC	Create normalized processing joins and complete risk, policy, access, vendor and audit aggregates.	All P0/P1 workflows persist without opaque relationship arrays.
4 - AI and reports	Add retrieval/safety/evaluation lineage and immutable stored report artifacts.	Question and report reproduction tests pass.
5 - Backfill and cutover	Backfill IDs, validate counts/hashes, dual read/write, compare, cut over and archive legacy fields.	Zero unresolved reconciliation differences.
6 - Scale hardening	Partition, tune indexes, load test, restore test and verify audit chain.	Production SLO, RPO/RTO and security gates pass.

6. Production Approval Gates

- All mandatory relationships use verified FKs or documented, tested asynchronous integrity controls.
- Every tenant table has deny-by-default RLS plus positive, negative and service-role bypass tests.
- Historical assessments, questions, evidence and reports reproduce after content/template/model upgrades.
- Cross-tenant object, search, vector, cache and export access tests pass.
- Migration rehearsal, rollback, PITR restore, object reconciliation and audit-chain verification pass at production-scale volume.
- No critical/high exploitable security finding or unresolved data-reconciliation defect remains.

7. Final Decision

Approve PostgreSQL/Supabase and the current operational foundations. Do not approve the current logical schema as complete. Approve the companion production schema as the target state, subject to executable migration DDL, threat modeling, load testing, security verification and staged cutover evidence.